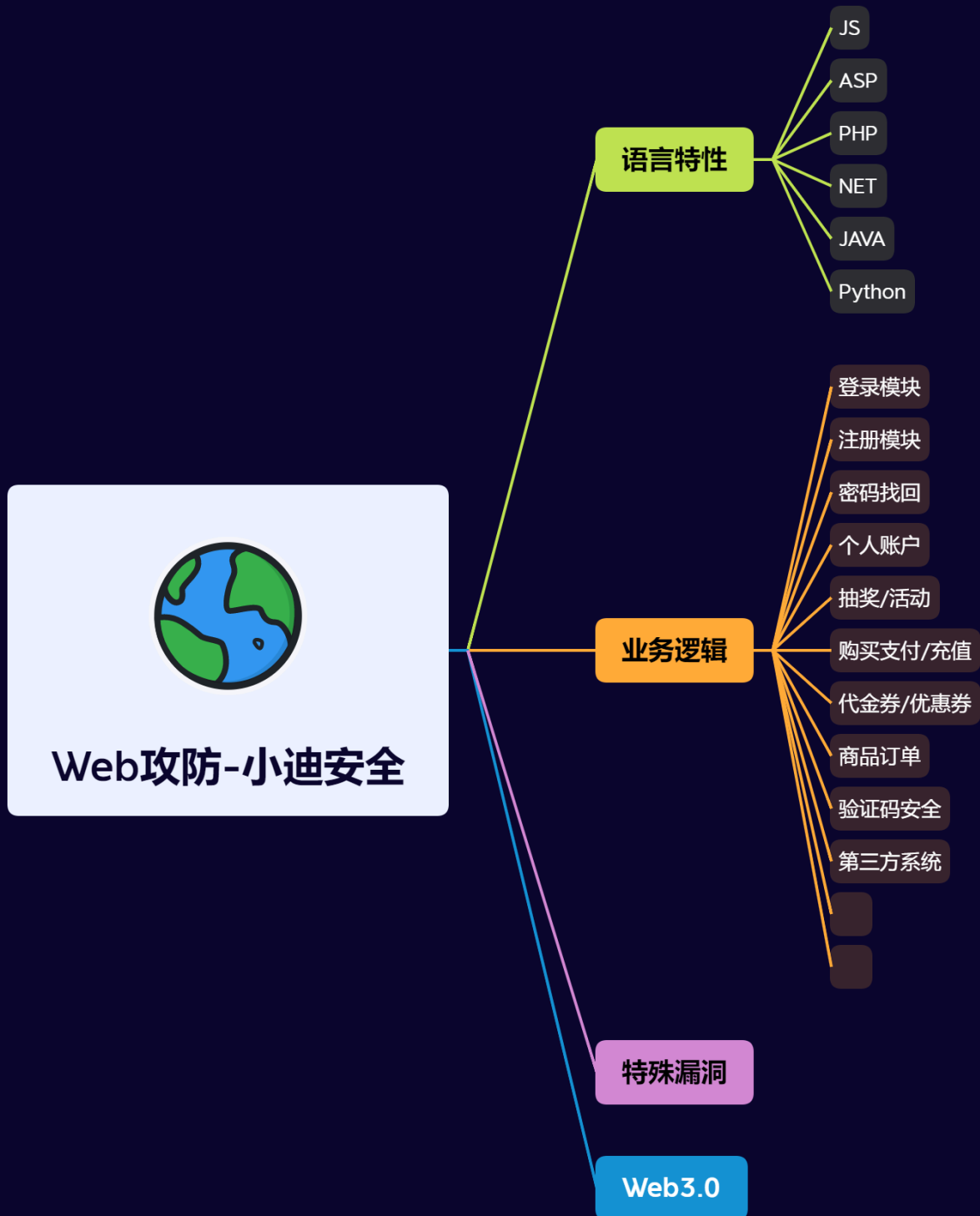


Day43 WEB攻防-PHP应用&SQL注入&符号拼接 &请求方法&HTTP头&JSON&编码类



1.知识点

- 1、ASP-SQL注入-Access数据库
- 2、ASP-默认安装-数据库漏洞下载
- 3、ASP-IIS-CVE&短文件&解析&写入

-
- 1、PHP-MYSQL-SQL注入-常规查询
 - 2、PHP-MYSQL-SQL注入-跨库查询
 - 3、PHP-MYSQL-SQL注入-文件读写

-
- 1、PHP-MYSQL-SQL注入-数据请求类型
 - 2、PHP-MYSQL-SQL注入-数据请求方法
 - 3、PHP-MYSQL-SQL注入-数据请求格式
-

2.演示案例

2.1 PHP-MYSQL-数据请求类型



- 1 SQL语句由于在黑盒中是无法预知写法的，SQL注入能发成功是需要拼接原SQL语句，大部分黑盒能做的就是分析后各种尝试去判断，所以有可能有注入但可能出现无法注入成功的情况。究其原因大部分都是原SQL语句的未知性导致的拼接失败！
- 2 由于开发者对于数据类型和SQL语句写法（框架写法）导致SQL注入拼接失败
- 3 1、数字型(无符号干扰)
- 4 `select * from news where id=$id;`
- 5 2、字符型（有符号干扰）
- 6 `select * from news where id='$id';`
- 7 3、搜索型（有多符号干扰）
- 8 `select * from news where id like '%$id%'`
- 9 4、框架型（有各种符号干扰）
- 10 `select * from news where id=(' $id');`
- 11 `select * from news where (id= ' $id');`

2.2 PHP-MYSQL-数据请求方法



- 1 全局变量方法：GET POST SERVER FILES HTTP头等
- 2 User-Agent:
- 3 使得服务器能够识别客户使用的操作系统，浏览器版本等。（很多数据量大的网站中会记录客户使用的操作系统或浏览器版本等存入数据库中）
- 4 Cookie:
- 5 网站为了辨别用户身份、进行session跟踪而储存在用户本地终端上的数据X-Forwarded-For: 简称XFF头，它代表客户端，也就是HTTP的请求端真实的IP，（通常一些网站的防注入功能会记录请求端真实IP地址并写入数据库or某文件[通过修改XXF头可以实现伪造IP]）。

```
6  Rerferer: 浏览器向 WEB 服务器表明自己是从哪个页面链接过来的。
7  Host: 客户端指定自己想访问的WEB服务器的域名/IP 地址和端口号
8
9  如功能点:
10 1、用户登录时
11 2、登录判断IP时
12 是PHP特性中的$_SERVER['HTTP_X_FORWARDED_FOR'];接受IP的绕过（绕过）
13 实现: 代码配置固定IP去判断-策略绕过
14 实现: 数据库白名单IP去判断-select注入
15 实现: 防注入记录IP去保存数据库-insert注入
16 3、文件上传将文件名写入数据库-insert注入
```

2.3 PHP-MYSQL-数据请求格式

- 
- 1 1、数据采用统一格式传输，后端进行格式解析带入数据库（json）
 - 2 2、数据采用加密编码传输，后端进行解密解码带入数据库（base64）